IT Security and Acceptable Use Policy

NimbusSoft Technologies Pvt. Ltd. | Version 5.1 | Effective 1 March 2025 | Owner: Information Security Office

This policy sets out the rules for using NimbusSoft information systems, devices and data securely. It applies to every employee, contractor and vendor account, and to every device that touches company data, whether issued by the company or personal. Following these rules is a condition of access to company systems.

SECTION 1: Purpose and Scope

The purpose of this policy is to protect the confidentiality, integrity and availability of company and customer information. It covers password and authentication standards, device usage, remote access, software installation, data classification, email security, incident reporting, backups and workplace hygiene.

SECTION 2: Password Requirements

All account passwords must be at least 12 characters long. Passphrases of three or more unrelated words are strongly recommended over complex short passwords. Passwords must not reuse any of your last 5 passwords.

There is no routine expiry for passwords; change your password immediately if you suspect it has been exposed, if the identity team notifies you of a breach, or after any suspected compromise. Passwords must never be shared, written on paper near your desk, or reused across personal and company accounts. A company-provided password manager is the approved place to store credentials.

SECTION 3: Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for VPN access, corporate email, the HRMS, cloud consoles and all remote access. MFA must be via the approved authenticator app; SMS-based OTP is permitted only where an authenticator app cannot be installed.

Employees with privileged or administrative access must use a hardware security key for all administrative logins. Losing your MFA device must be reported to the IT Service Desk immediately so the token can be revoked and re-issued the same day.

SECTION 4: Device Usage

Company data must be stored only on company-issued devices. Full-disk encryption (BitLocker on Windows, FileVault on macOS) is mandatory and must remain enabled at all times. Devices must auto-lock after a maximum of 5 minutes of inactivity, and you must lock your screen manually whenever you step away.

Jailbroken or rooted devices may never connect to company systems. Operating systems and browsers must receive security updates within 14 days of release. Company devices must not be

lent to family members or used to run unapproved business services.

SECTION 5: Remote Work Security

When working from home, co-working spaces or travel, connect to the company network only through the approved VPN client. Public Wi-Fi must never be used without the VPN. Home Wi-Fi networks must use WPA2 or WPA3 encryption with a unique password.

Work data must not be downloaded to personal devices, personal cloud storage or personal email under any circumstances. Video calls discussing confidential matters must use the approved conferencing tool with waiting rooms enabled.

SECTION 6: Software Installation

Software may be installed only from the Company Software Portal, where titles are vetted and licensed. Employees do not have local administrator rights by default; elevation requests are made through the Service Desk and expire after 24 hours.

Installing cracked, pirated or unapproved software is a critical violation of this policy, even on personal devices that also access company email. Browser extensions that read page content (including AI assistants and translators) must be approved before use on corporate data.

SECTION 7: Data Classification

All company information falls into one of four classes: Public, Internal, Confidential or Restricted. Public data may be shared freely. Internal data is for employees only. Confidential data (contracts, roadmaps, pricing) is shared on a need-to-know basis. Restricted data (customer PII, source code, financial records, credentials) may only be stored, processed and transmitted through approved systems with access logging.

Restricted data must never be pasted into unapproved external tools, including public AI chatbots and translation sites. Sharing Restricted data with third parties requires a signed non-disclosure agreement and Information Security approval.

SECTION 8: Email and Phishing

Treat every unexpected email, SMS and chat message as potentially hostile. Verify payment-detail changes and credential requests by phone using known contact details, never by replying to the message itself.

Report suspected phishing using the Report Phish button in your mail client within 24 hours of receipt. Quarterly phishing simulations are mandatory; repeated failures trigger refresher training. Never open unexpected attachments in sandboxed or unprotected environments.

SECTION 9: Security Incident Reporting

Report any suspected security incident - lost device, clicked phishing link, malware alert, unauthorised access, data exposure - to security@nimbussoft.example or the 24x7 hotline within 2

hours of discovery.

Do not power off or attempt to clean a compromised device; disconnect it from the network and leave it on so evidence can be preserved. The Information Security Office owns all decisions about regulatory breach notification, including the 72-hour notification window under applicable data-protection law. Do not discuss incidents outside the response team.

SECTION 10: Backups and Retention

Endpoints are backed up nightly with a weekly full backup, and backups are retained on a 90-day rolling window. Server and cloud data follow service-specific retention schedules published by the platform team. Deleted files can be restored by the Service Desk within the retention window.

SECTION 11: Clear Desk and Clear Screen

Confidential documents must not be left unattended on desks or printers. Lock printed material away, use the confidential-waste shredder for disposal, and collect printouts immediately. Whiteboards used in meetings must be photographed and wiped at the end of the day.

SECTION 12: Violations and Enforcement

Violations are classified as minor (for example, an unlocked screen), major (unapproved software holding company data) or critical (data exfiltration, credential sharing). Consequences range from refresher training to access revocation and termination of employment, and may include legal action where laws are broken. Suspected violations are investigated by the Information Security Office with HR involvement.